Verificando la calidad, la seguridad y el cumplimiento normativo

Auditoría técnica de Cuidarte+ · Módulo de pacientes

EQUIPO

Benjamín Ibáñez · Gerardo Vera González

FECHA

Octubre 2026

ALCANCE

8 casos · 7 pass · 1 fail

CP006 · SESIÓN NO REVOCADA



Cuidarte+ concentra datos clínicos; la auditoría se enfocó en la puerta de entrada

Cuidarte+ gestiona pacientes, exámenes y documentos clínicos. El módulo auditado fue el registro de pacientes (POST /pacientes), junto con los controles que protegen esos datos: autenticación, autorización, validación e integridad.

JWT | RBAC | POST /pacientes | Exámenes | Documentos

Auditoría | PostgreSQL | Docker Compose

SUPERFICIE AUDITADA

10.133 líneas de código

8 casos ejecutados

7 hallazgos

2 jornadas

ALCANCE DECLARADO

Entorno Docker del equipo, datos de prueba y módulo de pacientes. No es una auditoría de infraestructura ni de dispositivos médicos.

TRES ROLES, TRES LÍMITES

A — Admin

RB-2 · acceso total

Configura usuarios y ve todos los módulos.

M — Médico

RB-3 · información clínica

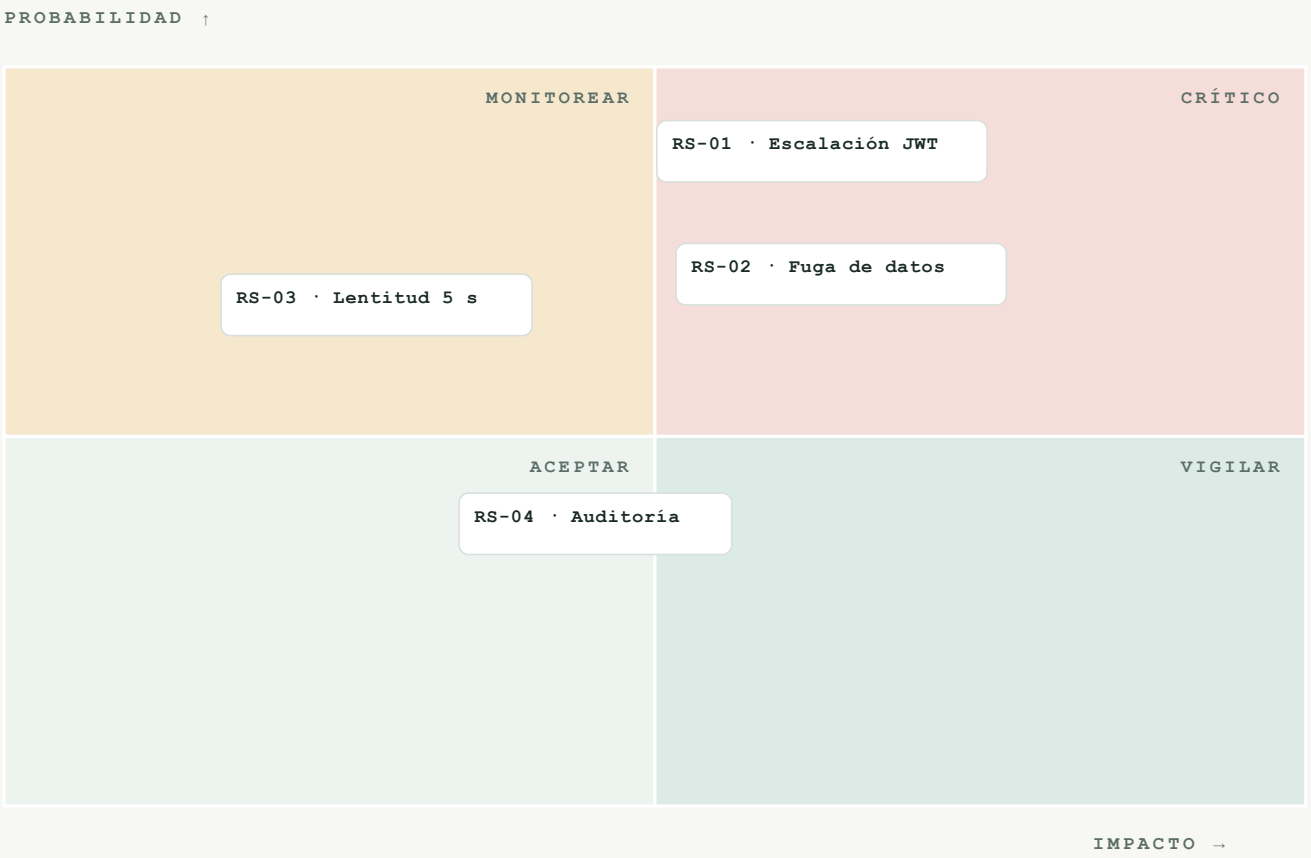
Accede a exámenes y documentos de sus pacientes.

P — Paciente

RB-1 · solo lectura

Consulta únicamente su propia información.

Priorizar por riesgo, no por cobertura aparente



CÓMO SE EJECUTÓ

01 **Revisión manual contra OWASP**

Contrato, validaciones y controles de acceso.

02 **SAST con SonarQube 9.9.8**

10.133 líneas, perfil OWASP, Quality Gate.

03 **Evidencia reproducible**

Docker + PostgreSQL + request/response.

CRITERIO DE ENTRADA

Entorno levantado, datos de prueba y token por rol.

CRITERIO DE SALIDA

8 casos ejecutados, evidencia archivada y 7 hallazgos clasificados.

Cada tipo nace de un requisito y de un riesgo concreto

FUNCIONAL · 4 CASOS

Registro y validación de entrada

Partición de equivalencia y valores límite sobre los campos del paciente.

RQ-07 · RF-2 · CP001–CP004

positivo · negativo · duplicado · borde

SEGURIDAD · 3 CASOS

Autenticación, sesión y autorización

JWT, revocación tras logout y control de rol sobre exámenes.

RQ-01/02 · NFR-SEG-4/9 · CP005–CP007

token válido · revocado · rol paciente

INTEGRIDAD · 1 CASO

Carga y descarga de documentos

Verificación byte a byte con SHA-256 y medición de tiempos.

RQ-03 · RF-4.2/4.3 · CP008

subida 201 · descarga 200 · hash igual

ESTÁTICO · SAST

Análisis estático con SonarQube

Complejidad cognitiva, duplicación y malas prácticas en 10.133 líneas.

ISO/IEC 25010 · NFR-SEG-1…9

73 issues · 8 críticos · QG OK

La selección fue proporcional al riesgo del módulo, no una cobertura exhaustiva de toda la plataforma.

Qué detecta cada tipo — y qué quedó fuera de alcance

Tipo	Defecto que detecta	Evidencia	Impacto
Funcional	Campos inválidos, duplicados y límites	CP002/003/004 → 400	Evita registros corruptos
Seguridad	Token reutilizable y rol indebido	CP006 → 200 · CP007 → 403	Acceso no autorizado a datos clínicos
Integridad	Pérdida o alteración de archivos	CP008 → SHA-256 idéntico	Documento clínico no confiable
Estático	Complejidad, duplicación y malas prácticas	73 issues · 8 críticos	Deuda y riesgo de mantenimiento

FUERA DE ALCANCE

- Carga con 200 usuarios
- Usabilidad con pacientes reales
- DAST con OWASP ZAP

No probado ≠ aprobado.

TIEMPOS OBSERVADOS

```
CP007 · 5.036 ms
CP008 · 5.050 ms subida
37 ms descarga
```

El delay de 5 s distorsiona la medición.

Los tiempos no se usan como criterio de aprobación: se reportan como observación.

Siete requisitos priorizados, ocho casos: cobertura completa con distinto nivel de evidencia

RQ	Requisito	Nivel de evidencia	Fuente
RQ-01	Autenticación y sesión	Caso formal · CP005–CP006	RF-1, NFR-SEG-9
RQ-02	Control de acceso por rol	Caso formal · CP007	RB-1..3, NFR-SEG-4
RQ-03	Exámenes y documentos	Caso formal · CP008	RF-3, RF-4.3
RQ-04	Tiempo y concurrencia	Observación · CP007/CP008	NFR-PERF-1..3
RQ-05	Auditoría de acciones	Revisión + CP001	RF-5.1
RQ-06	RUT con dígito verificador	Prueba manual · H-03	Validación RUT
RQ-07	Registro de pacientes	Caso formal · CP001–CP004	RF-2

Los RQ sin caso formal se verificaron por revisión de código o prueba manual: RQ-05 con CP001 y RQ-06 sin captura archivada.

4 RQ con caso formal

3 RQ con verificación directa

7/7 RQ cubiertos

COBERTURA DE REQUISITOS, NO DE CÓDIGO

SonarQube reporta 0,0% de cobertura automatizada.

Cinco herramientas, una razón por cada una

01	**Docker Compose**	Reproducir el entorno completo: frontend, backend y PostgreSQL.
02	**Swagger / OpenAPI**	Verificar el contrato real de cada endpoint antes de probarlo.
03	**curl / Postman**	Capturar request y response como evidencia reproducible.
04	**PostgreSQL**	Confirmar el efecto real de una petición en la base de datos.
05	**SonarQube 9.9.8**	SAST con perfil OWASP sobre 10.133 líneas de código.

POR QUÉ NO ZAP

OWASP ZAP no se ejecutó en esta iteración. Se declara como trabajo futuro, no como resultado.

Un hallazgo no observado no se convierte en un hallazgo inexistente.

ENTORNO

```
Docker Compose
PostgreSQL 15
SonarQube 9.9.8
```

Toda la evidencia quedó archivada con nombre, caso y resultado.

Dos jornadas, ocho casos y evidencia por cada uno

8 ejecutados

7 pass

1 fail

0 bloqueados

06 OCT

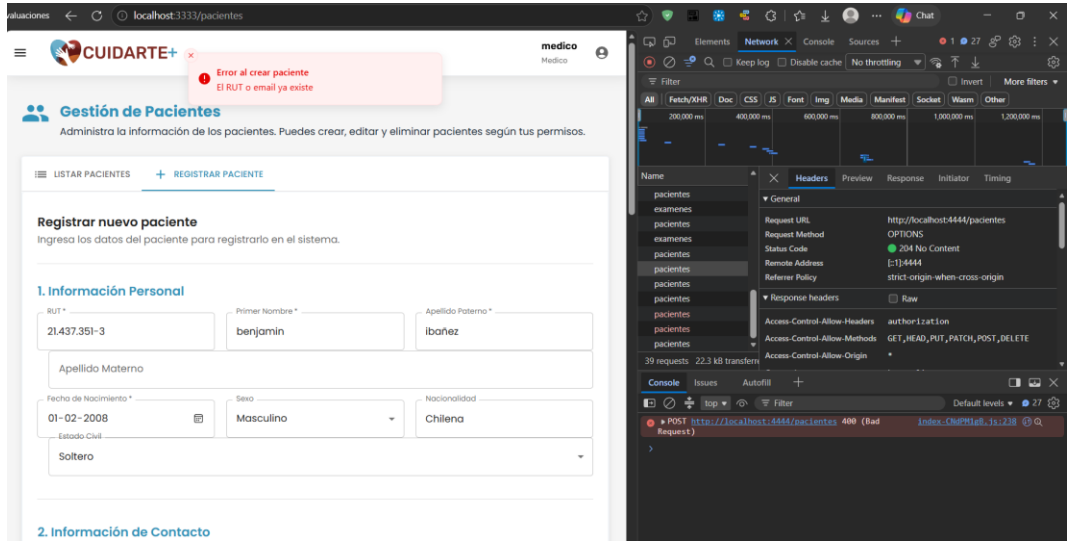
CP001–CP004 · 4 Pass

Registro de pacientes y validación de entrada.

16 OCT

CP005–CP008 · 3 Pass / 1 Fail

Sesión, RBAC, integridad y análisis estático.



CP003 · duplicado → 400

CP006 · FAIL

El token sobrevive al logout

Sin endpoint de logout · token previo aceptado (200) · esperado: 401

El cierre de sesión solo borra el token en el navegador; el servidor lo sigue aceptando.

QUÉ IMPLICA

Un atacante con un token robado conserva acceso a la lista de pacientes después de que la víctima cierre sesión. Incumple NFR-SEG-9 y OWASP A07.

Siete hallazgos: 1 crítico, 3 graves, 2 moderados y 1 leve

CRÍTICO	GRAVE	MODERADO	LEVE
1	3	2	1

CRÍTICO

H-01 · Contraseñas en texto plano

`auth.js:21` · `auth.js:110`

Cualquiera con acceso a la base de datos obtiene credenciales legibles.

GRAVE

H-02 · JWT sin revocación ni secreto propio

`auth.js:8, :44-55` · `docker-compose.yml:35`

Un token robado sigue vivo después del logout (CP006).

GRAVE

H-03 · RUT sin dígito verificador

`validations/pacientes.js:8` · `utils/rut.js:5-8`

Acepta 21.437.351-4; el dígito real es 3.

GRAVE · LATENTE

H-04 · Documentos servidos sin autenticación

`app.js:43`

Si se almacenaran en disco, cualquiera con la URL accedería sin sesión.

MODERADO

H-05 · Delay de 5 s

middleware/delay.js:5 · aplicado a pacientes, exámenes y documentos.

MODERADO

H-06 · CORS abierto

app.js:21 · cualquier origen puede llamar la API.

LEVE

H-07 · Errores internos expuestos

auth.js:67 · documentos.js:115 · err.message en la respuesta.

El Quality Gate está en verde; el cumplimiento legal no

QG OK
Quality Gate

0
vulnerabilidades

73
issues

8
críticos

0,0%
cobertura

465
min de deuda

ISSUES POR SEVERIDAD



25 PRIORIZADAS · FICHAS EN SECC. 5.4 + ANEXO B DEL INFORME

Hallazgo	Norma	Por qué es un incumplimiento
H-01 / H-02	OWASP A02/A07 · Ley 19.628	Credenciales y sesiones sin protección suficiente para datos sensibles de salud.
H-03	Ley 20.584	La ficha clínica se identifica con un RUT que puede ser inválido.
H-04	OWASP A01 · Ley 19.628	Documentos clínicos accesibles sin control de acceso.
0,0% cobertura	ISO/IEC 25010	Mantenibilidad y confiabilidad no verificadas por pruebas automatizadas.

SonarQube mide patrones; la ley exige deberes. 0 vulnerabilidades automáticas no significa 0 riesgos reales.

Lo que funcionó, lo que falló y lo que decidimos no ocultar

Calidad

BIEN RBAC, validaciones y auditoría responden.

BRECHA 73 issues y 14,5% de duplicación.

CP001–CP008 · SonarQube

Seguridad

BIEN JWT y roles bloquean accesos indebidos.

BRECHA H-01 y CP006: credenciales y sesión.

CP005–CP007

Normativo

BIEN Auditoría y trazabilidad de acciones.

BRECHA Ley 19.628 incumplida en H-01/H-02/H-04.

Ley 19.628 · Ley 20.584

Ético

BIEN El Fail se reporta con evidencia.

BRECHA Falta DAST y carga; se declara, no se omite.

Bitácora + 28 evidencias

La utilidad de una auditoría se mide por lo que revela, no por lo que confirma.

GO CONDICIONADO: cuatro correcciones antes de producción

VEREDICTO

GO CONDICIONADO

Si H-01 a H-04 no se corrigen, el veredicto es NO-GO.

Alcance: módulo de pacientes y controles asociados.

Antes de producción, no después de un incidente.

01 H-01 **Hash de contraseñas con bcrypt o argon2**

Ninguna contraseña legible en la base de datos.

02 H-02 **Revocación de JWT y secreto por entorno**

Token inválido tras logout; sin secreto por defecto.

03 H-03 **Dígito verificador de RUT (módulo 11)**

21.437.351-4 rechazado; 21.437.351-3 aceptado.

04 H-04 **Autenticación en /files/documentos**

Documento sin sesión → 401.

Ley 19.628 y 20.584: con datos clínicos, la seguridad es un deber de cuidado, no un ítem de checklist.

La calidad no termina en un gate verde.
Termina cuando el sistema protege a quien confía en él.



Gracias. Preguntas.

Benjamín Ibáñez · Gerardo Vera

Anexos A–D disponibles para trazabilidad, métricas, normativa y evidencias.

Ocho casos, un resultado por caso

Caso	RQ	Tipo	Resultado	Evidencia
CP001	RQ-07	Funcional positivo	PASS	Grupo1_CP001_Front_201_Pass.png
CP002	RQ-07	Funcional negativo	PASS	Grupo1_CP002_Backend_400_Pass.png
CP003	RQ-07	Duplicado	PASS	Grupo1_CP003_Duplicado_400_Pass.png
CP004	RQ-07	Valor límite	PASS	Grupo1_CP004_Backend_400_Pass.png
CP005	RQ-01	Seguridad · login	PASS	Grupo1_CP005_Login_200.json
CP006	RQ-01	Seguridad · logout	FAIL	Grupo1_CP006_Reuso_token_tras_logout_200.json
CP007	RQ-02	Seguridad · RBAC	PASS	Grupo1_CP007_PUT_403.json
CP008	RQ-03	Integridad	PASS	Grupo1_CP008_Integridad_y_tiempo.txt

Todos los archivos están en Mis_Entregables/U2.3_Ejecucion/Evidencias/.

El detalle detrás del Quality Gate

Métrica	Valor
Líneas de código	10.133
Issues	73
Críticos	8
Vulnerabilidades	0
Cobertura	0,0%
Duplicación	14,5%
Deuda técnica	465 min

RATINGS

Mantenibilidad A · Seguridad A · Confiabilidad C

Las 25 incidencias priorizadas (SQ-01 a SQ-25) están documentadas en la sección 5.4 y el Anexo B del informe, con explicación en español, código real y JSON.

Archivo:línea	Complejidad
SQ-08 · UsuarioForm.jsx:173	39
SQ-06 · ExamenForm.jsx:47	33
SQ-04 · users.js:283	27
SQ-05 · users.js:437	24
SQ-07 · PacienteForm.jsx:21	22
SQ-02 · pacientes.js:48	22
SQ-03 · pacientes.js:276	21
SQ-01 · auth.js:71	17

Los ocho críticos (SQ-01 a SQ-08) son S3776: complejidad cognitiva alta. Top 3: SQ-08 (39), SQ-06 (33), SQ-04 (27).

El Quality Gate evalúa las condiciones configuradas; no equivale a una auditoría de seguridad.

Qué exige la norma y dónde falla Cuidarte+

Norma	Qué exige	Dónde se incumple
Ley 19.628	Proteger datos personales sensibles, confidencialidad y seguridad.	H-01, H-02 y H-04: credenciales, sesión y documentos.
Ley 20.584	Reserva de la ficha clínica y acceso controlado y trazado.	H-02 y H-03: sesión no revocada; RUT inválido.
OWASP A01	Controlar el acceso a recursos y funciones.	H-04: /files/documentos sin autenticación.
OWASP A02/A07	Proteger credenciales y sesiones.	H-01/H-02: texto plano y JWT sin revocación.
ISO/IEC 25010 · NFR-SEG-8/9	Calidad verificable y cumplimiento normativo.	0,0% cobertura y controles de sesión incompletos.

El análisis no constituye asesoría legal: es una lectura técnica del ERS y de la normativa chilena aplicable.

28 archivos, una convención y trazabilidad por caso

28 archivos

6 PNG

15 JSON

7 TXT + PDF

CONVENCIÓN DE NOMBRE

Grupo1_<CP>_<vista>_<resultado>.<ext>

```
Grupo1_CP001_Front_201_Pass.png
Grupo1_CP006_Reuso_token_tras_logout_200.json
Grupo1_CP008_Integridad_y_tiempo.txt
```

Caso, vista, resultado y extensión: la evidencia se puede ubicar sin abrir la bitácora.

Grupo	Archivos	Qué demuestra
CP001–CP004	6 PNG + request/response	Validación funcional y duplicado.
CP005–CP007	JSON + TXT	Login, logout y RBAC.
CP008	PDF + TXT	Integridad documental y tiempos.
SonarQube	5 JSON/TXT	Análisis estático y Quality Gate.

La bitácora completa está en U2.3_Ejecucion/Bitacora_Ejecucion_2.3_Cuidarte.docx.

Cada resultado Pass o Fail tiene al menos un archivo asociado.